

Agentic Governance Framework (AGF): Deterministic Compliance Evaluation with Cryptographic Audit Integrity

Technical Whitepaper v1.0

NeuroCluster · March 2026

Preface: Research Memo and Claim Audit

This whitepaper was developed through systematic review of the draft technical materials produced by the AGF engineering team, verified against primary regulatory sources, technical standards, and peer-reviewed literature. The following memo summarizes the audit of claims from the original draft and the revisions applied.

A. Claim Audit Summary

#	Draft Claim	Evidence	Support	Revision
1	“\$270B annual compliance spending”	LexisNexis 2024: \$206B globally for financial crime compliance. Thomson Reuters and Oxford Economics report 12% annual increase.	Overstated. The \$270B figure is not traceable to any published source.	Revised to “\$206 billion” with LexisNexis citation.
2	“80% of compliance checks are manual”	Widely cited in industry surveys but no single authoritative primary source. BPI/Sayari 2024 report documents 61% increase in employee compliance hours since 2016.	Partially supported. The figure is directionally correct but not precisely sourced.	Revised to “a significant majority of compliance activities remain manual” with supporting evidence.

#	Draft Claim	Evidence	Support	Revision
3	"False positive rates in sanctions screening exceed 95%"	Multiple industry sources (Flagright, LexisNexis, Columbia University) cite 90–95% false positive rates for AML alerts. The specific "95%+" is at the upper bound.	Partially supported. 90–95% is the documented range.	Revised to "commonly reported in the range of 90–95%."
4	"Tamper-evidence is mathematically impossible to defeat"	Hash chains provide computational infeasibility of tampering under standard cryptographic assumptions, not mathematical impossibility in an absolute sense.	Overstated. Conflates computational hardness with impossibility.	Revised to "computationally infeasible to tamper with under standard assumptions."
5	"Deterministic evaluation satisfies Article 14 human oversight"	EU AI Act Article 14 requires oversight by natural persons, including ability to intervene and override. Determinism aids transparency but does not itself satisfy the requirement.	Misleading. Determinism supports interpretability but is not equivalent to human oversight.	Revised to "supports the interpretability dimension" with explicit caveat.

#	Draft Claim	Evidence	Support	Revision
6	"Exceeds FCA SYSC 9 requirements"	FCA is technology-neutral. SYSC 9 requires records sufficient for supervisory review. Cryptographic trails are compatible but "exceeds" is a legal conclusion.	Overstated. Engineering alignment ≠ legal compliance determination.	Revised to "is consistent with the technology-neutral requirements" with caveat.
7	"< £0.001 cost per evaluation"	Based on compute-only marginal cost at prototype scale; ignores infrastructure, licensing, staff, deployment.	Misleading. Marginal compute cost is not total cost.	Revised to "marginal compute cost" with caveats about total cost of ownership.
8	"Any third party can verify without access to underlying data"	A verifier can confirm the signature and hash chain but cannot verify that the input data was correct or complete.	Partially supported. Verification scope is limited.	Revised with explicit distinction between execution integrity and data integrity.
9	Blake3 and Ed25519 described without caveats	Blake3 has no IETF or NIST standardization (expired draft). Ed25519 is specified in RFC 8032 (IRTF informational). Neither has formal regulatory endorsement.	Missing context.	Added standardization status and maturity notes.

#	Draft Claim	Evidence	Support	Revision
10	“SP1 zkVM proven” described alongside production features	SP1 conformance testing was performed but proving is optional and off the real-time path, not the default production feature.	Conflated. Must clearly distinguish demonstrated from deployed.	Separated into prototype / batch ZK vs. default signed-audit kernel; control plane vs kernel documented in §5.

B. Key Revisions Applied

1. All quantitative claims revised to cite primary sources or qualified as estimates
2. Legal conclusions replaced with engineering-alignment statements
3. Explicit limitations section addressing data integrity, rule formalization risk, key management, and benchmark realism
4. Architecture critique added: signing boundary, canonical serialization, metadata privacy, key rotation
5. Comparison section rewritten as analytical rather than promotional
6. Zero-knowledge roadmap clearly separated from production capabilities

Executive Summary

The Agentic Governance Framework (AGF) is a deterministic compliance evaluation kernel that formalizes regulatory rules as machine-readable specifications, evaluates structured context (e.g. entity attributes or proposed agent-action fields) against those rules, and produces a cryptographically signed, hash-chained audit trail. In a full product architecture, that kernel is paired with a governance control plane: operator-facing surfaces for agent onboarding, policy lifecycle, risk and trust signals, human-in-the-loop (HITL) workflows, reporting, and framework integrations. This paper focuses on the kernel and its cryptography; the control plane is organizational and UX orchestration and must not silently override deterministic verdict mathematics.

Trust scores, dashboards, and workflow routing are valuable for adoption and oversight, but they are not a substitute for formal allow/deny logic: high-risk actions still require explicit rule outcomes (and often human approval) rather than a probabilistic score alone.

This paper describes the design and prototype implementation of AGF, situating it within the broader landscape of regulatory technology (RegTech), policy-as-code, and cryptographic audit systems. We present the kernel architecture, the ARSL rule specification language, the evaluation semantics, the cryptographic audit model, and the isolation architecture. We also describe an optional, off-hot-path research direction toward zero-knowledge proofs of correct evaluation using the SP1 zkVM — distinct from the default production posture of direct evaluation plus Ed25519 signing.

We are explicit about what AGF proves and what it does not. The system provides integrity guarantees over the evaluation process — it does not validate the accuracy or complete-

ness of input data, nor does it substitute for legal interpretation of regulatory text. We discuss the limitations, trust boundaries, and open questions that remain before such a system could be deployed in a production regulatory context.

Abstract

Financial compliance evaluation is predominantly manual, slow, and difficult to audit independently. We present the Agentic Governance Framework (AGF), a system that compiles regulatory rules expressed in a domain-specific language (ARSL) into deterministic evaluation functions, executes those functions against structured evaluation inputs, and produces a tamper-evident audit record signed with Ed25519 and hash-chained with Blake3. We position AGF in a two-layer architecture: a governance control plane (configuration, risk signals, HITL, integrations) does not execute policy math; the enforcement kernel does, with no outbound I/O during evaluation. The evaluation runs inside a Kata Containers micro-VM on Kubernetes with zero-egress network isolation. We describe the system design, report prototype performance (26 rules evaluated in under 3 ms end-to-end), and outline an optional, off-hot-path direction for zero-knowledge proof of correct evaluation via SP1 zkVM — distinct from the default signed-audit production path. We critically assess the trust model, distinguish execution integrity from data integrity, caution against using probabilistic trust scores as a substitute for formal allow/deny logic, and identify open questions regarding rule formalization, key management, regulatory acceptance, and production readiness.

1. Introduction

Regulatory compliance in financial services is a process of determining whether an entity's activities, attributes, or financial position satisfy requirements imposed by statute, regulation, or supervisory guidance. This process is conventionally performed by compliance officers reviewing documentation, running queries against internal systems, and exercising professional judgment — activities that are labor-intensive, difficult to reproduce, and challenging to audit after the fact.

The cost of this activity is substantial. The LexisNexis True Cost of Financial Crime Compliance Study (2024) estimates global spending on financial crime compliance at approximately \$206 billion annually [1]. Banks' IT budgets allocated to compliance functions grew by approximately 40% between 2016 and 2023, with the compliance share of IT spending increasing from 9.6% to 13.4% [2]. Employee hours dedicated to compliance-related activities increased by 61% over the same period [3]. The Thomson Reuters Cost of Compliance Report (2025) found that 95% of surveyed firms reported year-over-year compliance cost increases [4].

These trends create demand for systems that can automate the evaluable portion of compliance — rules that can be formalized as deterministic checks against structured data. AGF is designed to address this subset of the compliance problem. It does not attempt to automate judgment-dependent assessments, but rather to provide a cryptographically verifiable record that a defined set of rules was evaluated correctly against specified inputs.

1.1 Scope and Non-Claims

This paper describes a prototype system and makes the following non-claims explicitly:

- AGF does not guarantee legal compliance. Legal compliance depends on the correctness and completeness of rule formalization, the accuracy of input data, jurisdictional interpretation, and supervisory acceptance — none of which the system itself can guarantee.
 - AGF does not validate input data. The cryptographic audit trail attests to the integrity of the evaluation process, not to the truth of the data evaluated.
 - AGF is not a zero-knowledge proof system in the default production evaluation path. The ZK proving capability has been demonstrated in a prototype (19 conformance cases proven on SP1 zkVM v6.0.2). Proving is suitable only for optional batch or high-assurance workflows (typical proving latency seconds to minutes), not for replacing real-time kernel evaluation and signing.
 - Trust and risk scores do not replace rules. Where a broader product exposes scores or trust metrics, they inform orchestration and prioritization; deterministic rule outcomes (and HITL where configured) remain the primary enforcement boundary.
-

2. Problem Definition and Industry Context

2.1 The Compliance Evaluation Problem

A compliance evaluation, in its simplest form, answers: given an entity's attributes and a set of regulatory rules, does the entity satisfy all applicable requirements? In practice, this involves:

1. Rule identification: Determining which regulations, articles, and thresholds apply to a given entity type and jurisdiction.
2. Data collection: Gathering the entity's financial, operational, or identity data relevant to those rules.
3. Evaluation: Comparing entity data against rule thresholds and conditions.
4. Decision: Producing a pass/fail/escalate determination.
5. Record-keeping: Documenting the evaluation for auditors and regulators.

Steps 1 and 2 typically involve significant manual effort. Step 3 is often also manual, even when the underlying check is mechanical (e.g., "Is the capital ratio above 8%?"). Step 5 commonly produces unstructured artifacts — PDFs, spreadsheets, email threads — that are difficult to verify independently.

2.2 Sanctions Screening Inefficiency

Sanctions screening provides a particularly acute example. Financial institutions screen customers and transactions against lists published by HM Treasury, OFAC, and equivalent bodies. Industry analyses commonly report false positive rates in the range of 90–95% for AML transaction monitoring alerts [5][6]. A large institution may investigate tens of thousands of alerts annually, the vast majority of which prove to be legitimate transactions flagged due to partial name matches, transliteration variants, or overly broad rule calibration [7]. The operational cost of investigating these false positives is substantial, and the resulting alert fatigue creates a risk that genuine threats are overlooked [8].

2.3 Audit Evidence Quality

The evidentiary quality of compliance records is a distinct but related concern. Current practice typically relies on attestations, reports, and logs stored in databases protected by access controls. These records are trust-based: a regulator or auditor must trust that the record was produced by the claimed process at the claimed time and has not been subsequently altered. There is no standard mechanism for a third party to independently verify the integrity of a compliance evaluation artifact without access to the system that produced it.

3. Prior Art and Related Work

3.1 Governance, Risk, and Compliance (GRC) Platforms

Enterprise GRC platforms (e.g., ServiceNow GRC, Archer, MetricStream) provide workflow, policy management, and reporting capabilities. These systems are primarily governance management tools rather than evaluation engines. They track obligations, assign ownership, and aggregate status, but the actual evaluation of compliance is typically performed by humans or by ad-hoc integrations with downstream systems. GRC platforms do not generally produce cryptographically verifiable evaluation records.

3.2 Policy-as-Code

The policy-as-code paradigm, exemplified by Open Policy Agent (OPA) and its Rego language [9], HashiCorp Sentinel, and AWS Config Rules, applies the principle of codifying policies as executable specifications. OPA has been successfully adopted for infrastructure authorization and Kubernetes admission control. However, its adoption for regulatory compliance in financial services remains nascent. The primary gap is that financial regulation is typically expressed in natural language with significant interpretive ambiguity, and the mapping from regulatory text to executable policy is a non-trivial act of legal-engineering translation that introduces formalization risk [10].

3.3 Machine-Readable Regulation

Proposals for machine-readable regulation (MRR) envision regulators publishing rules in formats that can be directly consumed by compliance engines [11]. This concept has been explored by the FCA's Digital Regulatory Reporting initiative [12] and by academic work arguing that regulators should treat machines as a primary audience for regulatory text [13]. While conceptually compelling, practical implementation of MRR at scale remains limited, and AGF's ARSL represents a firm-authored formalization rather than a regulator-published standard.

3.4 Tamper-Evident Logs and Transparency Systems

The concept of tamper-evident, append-only logs has extensive precedent. Google's Certificate Transparency [14] uses Merkle trees to create a publicly verifiable log of TLS certificates. Trillian [15] generalizes this pattern. Blockchain-based systems provide another instantiation. AGF's Blake3 hash-chained Immutable Audit Log (IAL) follows a simpler linear-chain model suited to a single-writer compliance engine, offering tamper evidence without the complexity of a distributed consensus mechanism.

3.5 Confidential Computing and Trusted Execution

Confidential computing, as promoted by the Confidential Computing Consortium, uses hardware-based Trusted Execution Environments (TEEs) to protect data in use [16]. Technologies such as AMD SEV-SNP, Intel TDX, and Arm CCA provide memory encryption and remote attestation at the hardware level. Kata Containers [17] provide VM-level isolation via QEMU micro-VMs, which is distinct from — and weaker than — full confidential computing. Without TEE hardware, Kata provides workload isolation (defense against container escape) but not confidentiality (protection of workload memory from a compromised host). This distinction is important for AGF’s trust model.

3.6 Zero-Knowledge Proofs for Verifiable Computation

Zero-knowledge proof systems enable a prover to demonstrate that a computation was performed correctly without revealing the inputs. Systems relevant to AGF include SP1 zkVM [18] (RISC-V based, developed by Succinct Labs), RISC Zero [19], and Jolt [20]. SP1 was designated “production-ready” in August 2024 for blockchain workloads [21] and has since demonstrated proving of Ethereum blocks in under 12 seconds using GPU clusters [22]. However, the application of ZK proofs to compliance evaluation is novel and has no established production precedent outside blockchain validation.

4. Conceptual Model: Compliance as Deterministic Computation

AGF’s core design premise is that a defined subset of compliance evaluation can be modeled as a pure function:

`evaluate : (RuleSet, EvaluationInput) -> EvaluationResult`

Where: - RuleSet is a set of formally specified compliance rules with defined thresholds, conditions, and comparison operators. - EvaluationInput is a dictionary of named fields mapping to values — typically entity attributes in KYC-style checks, or structured fields describing a proposed agent action in AI governance deployments. - EvaluationResult is a set of per-rule pass/fail determinations with margin-to-threshold metrics.

The function is deterministic: the same inputs always produce the same output. It is side-effect-free: it performs no I/O, no randomness, and no network access during execution. These properties are necessary preconditions for three downstream guarantees:

1. Reproducibility: Any party with the same inputs and rule definitions can independently reproduce the evaluation result.
2. Auditability: The evaluation can be re-executed to verify a historical result.
3. Provability: The evaluation can, in principle, be proven correct via a zero-knowledge proof without re-executing it.

4.1 What This Model Does Not Capture

The deterministic model captures the mechanical portion of compliance evaluation. It does not capture:

- Rule selection: Determining which rules apply to a given entity requires legal and contextual judgment that precedes the evaluation.
- Data sourcing: The accuracy and completeness of input data depends on upstream systems and processes outside the evaluation boundary.

- Interpretive discretion: Many regulatory provisions require professional judgment (e.g., “reasonable steps,” “adequate arrangements”) that cannot be reduced to threshold comparisons.
- Contextual assessment: Some compliance determinations depend on qualitative factors (e.g., the quality of an institution’s governance arrangements) that resist formalization.

AGF is designed for rules that can be formalized as threshold checks, membership tests, boolean conditions, and range comparisons. This is a proper subset of the full compliance evaluation domain, but it covers a substantial volume of routine checks — particularly in KYC, sanctions screening, capital adequacy, and data-processing consent.

5. System Architecture

5.0 Control plane and enforcement kernel

A complete AI governance deployment may include management surfaces (dashboards, agent registration, decentralized identifiers for traceability, SCIM/RBAC, trust and risk telemetry, HITL queues, notifications, regulatory exports) and integration adapters (e.g. orchestrators such as Temporal). Those components constitute the governance control plane. They publish policy versions, route approvals, and observe outcomes — but they do not evaluate rules inside the isolated runtime.

The enforcement kernel is the narrow subsystem that parses ARSL, compiles batches, runs the pure evaluation function, updates the IAL, and signs results. Keeping policy math inside the kernel preserves a clear audit story: operators can change UX and workflows without conflating those changes with verdict reproducibility.

The five layers below describe only the enforcement kernel pipeline.

5.1 The five-layer kernel pipeline

Layer 1 — Rule Definition (ARSL). Compliance rules are authored in the AGF Rule Specification Language, a TOML-based domain-specific language. Each rule specifies a condition type, field reference, threshold, and enforcement action, with metadata linking to the source regulation. For enterprise adoption, parallel policy-as-code formats (e.g. OPA/Rego-class packs) may be integrated at the compilation boundary; this paper treats ARSL as the canonical prototype representation.

Layer 2 — Compilation. The ARSL parser validates rule syntax and semantics, then compiles rules and evaluation inputs into a `ComplianceBatch` — a typed, validated intermediate representation suitable for evaluation.

Layer 3 — Deterministic Evaluation. The evaluation function processes the `ComplianceBatch` and produces an `EvaluationResult` containing per-rule compliance status and margin-to-threshold in basis points. Enforcement metadata may map outcomes to allow, block, or human-escalation paths in integrated systems. This function is a pure function with no I/O or state.

Layer 4 — Cryptographic Audit. The result is hashed with Blake3, appended to a hash-chained Immutable Audit Log (IAL), and signed with Ed25519. The signature covers a canonical message binding the proof hash (commitment to evaluation inputs and counts),

chain hash, and timestamp. This is a digital signature over a hash chain, not a zero-knowledge proof.

Layer 5 — Isolation. The evaluation runs inside a hardened container (distroless image, nonroot user, read-only filesystem, dropped capabilities) deployed within a Kata Containers QEMU micro-VM on Kubernetes with zero-egress network policy.

5.2 Multi-Vertical Evaluation

The `POST /evaluate-entity` endpoint evaluates a single entity across multiple ARSL rule files (verticals) in one call. This produces per-vertical results and a combined audit bundle with a single signature, enabling cross-regulatory assessments (e.g., KYC + sanctions + capital adequacy + GDPR) to be performed and attested atomically.

6. Rule Representation: ARSL

The AGF Rule Specification Language (ARSL) is a TOML-based format in which each rule specifies:

Component	Description	Example
Metadata	Jurisdiction, regulator, regulation reference, effective date	<code>jurisdiction = "UK", regulator = "FCA", regulation_ref = "CRR Article 92(1)(c)"</code>
Condition	Type, field, threshold, unit	<code>type = "minimum", field = "capital_ratio", threshold = 800, unit = "bps"</code>
Enforcement	Action on pass/fail	<code>on_pass = "allow", on_fail = "block"</code>
Source	Regulation text and article reference	<code>article = "Article 92(1)(c)", text = "...total capital ratio of 8%"</code>

6.1 Condition Types

ARSL v0.1.0 supports six condition types:

- `minimum` — field value must be $\geq$ threshold
- `maximum` — field value must be $\leq$ threshold
- `range` — field value must be within `[min_threshold, max_threshold]`
- `boolean_true` — field value must be non-zero (truthy)
- `equals` — field value must equal threshold
- `not_member_of` — field value must not appear in a blocked-values list

6.2 Current Verticals

The prototype implements 26 rules across four regulatory verticals:

- KYC Standard Onboarding (6 rules): MLR 2017, FCA SYSC 6.3 — age gate, AML risk score, ID verification, jurisdiction, PEP status, sanctions name match.
- HMT Financial Sanctions (5 rules): SAMLA 2018, IEEPA/EO 13224 — counterparty and UBO jurisdiction, currency, OFAC SDN name match, large-transaction reporting.
- FCA Capital/Consumer Duty (10 rules): CRR/CRR2, DORA, Solvency II — capital adequacy, liquidity coverage, leverage, net stable funding, large exposure, ICT reporting, solvency, Tier 1 capital, countercyclical buffer, stressed capital.
- GDPR/EU AI Act (5 rules): GDPR 2016/679, EU AI Act 2024/1689 — explicit consent, special-category consent, erasure gate, retention period, prohibited-AI-practice gate.

6.3 Formalization Risk

A critical observation is that ARSL rules are authored by the AGF implementer, not published by regulators. Each rule represents an engineering interpretation of regulatory text. This introduces formalization risk: the rule may not accurately or completely capture the regulatory intent. For example:

- A threshold expressed in basis points may not account for transitional provisions or supervisory buffers.
- A “not_member_of” blocked-values list requires maintenance as sanctions designations evolve.
- Boolean conditions may oversimplify requirements that have exceptions or qualifications in the source regulation.

Robust operational governance — including legal review of rule definitions, change-control processes, and version management — is essential for the credibility of ARSL-based evaluation.

7. Evaluation Semantics and Determinism

7.1 Evaluation Function

The evaluation function processes each rule in a `ComplianceBatch` and produces a per-rule result containing:

- `compliant`: `bool` — whether the entity data satisfies the rule condition.
- `actual_value`: `u64` — the entity’s value for the rule’s field.
- `margin_bps`: `i64` — signed margin-to-threshold in basis points, providing a measure of proximity to the compliance boundary.

The aggregate result includes `all_compliant` (logical AND of per-rule results), `pass_count`, and `block_count`.

7.2 Determinism Guarantees

The evaluation function is implemented as a pure function in Rust with the following properties:

- No I/O: The function operates entirely on in-memory data structures.
- No randomness: There are no random or pseudo-random operations.
- No floating-point: All arithmetic is performed on unsigned 64-bit integers to avoid floating-point non-determinism.

- No allocator dependence: The function does not depend on allocation order or memory layout for its results.

These properties ensure that the function produces identical output for identical input across platforms, compiler versions, and executions — a prerequisite for both audit reproducibility and zero-knowledge provability.

8. Cryptographic Audit Architecture

8.1 Immutable Audit Log (IAL)

Each evaluation result is appended to an in-memory, hash-chained audit log. Each entry contains:

- `log_id`: `u64` — monotonically increasing sequence number.
- `proof_hash`: `String` — Blake3 hash of the evaluation input parameters (rule file, entity ID, pass/block counts).
- `chain_hash`: `String` — Blake3 hash of `previous_chain_hash || current_entry`, creating a sequential dependency.
- `timestamp_utc`: `String` — RFC 3339 timestamp of the evaluation.

The chain hash structure provides tamper evidence: modification of any historical entry would change its hash, breaking the chain for all subsequent entries. This is computationally infeasible to reverse under standard assumptions about the preimage resistance of Blake3.

8.2 Ed25519 Signing

Each evaluation result is signed using Ed25519 (RFC 8032 [23]). The canonical signing message is:

```
AGF-EVAL-V1:{proof_hash}:{chain_hash}:{timestamp_utc}
```

This binds the signature to both the evaluation content (proof hash) and the audit-log position (chain hash), preventing reordering or substitution of signed results.

Signing key management. The current prototype loads the Ed25519 signing key from an environment variable (`AGF_SIGNING_KEY_HEX`), provisioned as a Kubernetes Secret. If no key is provided, an ephemeral key is generated. This is adequate for demonstration but insufficient for production, where a key management system (KMS) with rotation policies, HSM backing, and access controls would be required. The trust model for signature verification depends entirely on the security of the signing key: a compromised key allows the holder to produce arbitrary signed results indistinguishable from genuine ones.

8.3 Verification Model

A third party can verify a signed evaluation result by:

1. Obtaining the server's public key from `GET /public-key`.
2. Reconstructing the canonical signing message from the result's proof hash, chain hash, and timestamp.
3. Verifying the Ed25519 signature.

The `agf-verify` CLI tool automates this process. Successful verification confirms that:

- The result was produced by the holder of the corresponding private key.
- The proof hash and chain hash have not been altered since signing.

What verification does not confirm: Verification does not confirm that the input data was correct, that the rules were correctly formalized, or that the evaluation logic is sound. It confirms only the integrity of the signed artifact. This is an important distinction: cryptographic integrity of the record is a necessary but not sufficient condition for the reliability of the compliance assessment.

8.4 Cryptographic Primitive Selection

Blake3 was selected for hashing due to its high performance (designed for parallelizable computation on modern hardware), its avoidance of length-extension attacks, and its suitability for hash-chaining applications [24]. Blake3 targets 128-bit security for preimage, collision, and differentiability resistance. It should be noted that Blake3 has not achieved formal IETF or NIST standardization; an IETF Internet-Draft (draft-aumasson-blake3-00) exists but has expired [25]. For contexts requiring regulatory-endorsed hash functions, SHA-256 or SHA-3 (NIST FIPS 180-4 / FIPS 202) may be preferred, and the architecture permits substitution.

Ed25519 was selected for digital signatures as specified in RFC 8032 [23]. It provides 128-bit security, deterministic nonce generation (eliminating a class of implementation vulnerabilities), and compact 64-byte signatures. Ed25519 is widely adopted (including anticipated inclusion in NIST FIPS 186-5 [26]) and supported by the `ed25519-dalek` Rust implementation.

9. Isolation, Trust, and Attestation Model

9.1 Software Isolation

The AGF server runs inside a hardened Docker container with the following security constraints:

- Distroless base image (`gcr.io/distroless/cc-debian12`): minimal attack surface with no shell, package manager, or unnecessary binaries.
- Non-root execution: The process runs as UID 65534 (`nonroot`).
- Read-only filesystem: The container filesystem is mounted read-only.
- Dropped capabilities: All Linux capabilities are dropped (`cap_drop: ALL`).
- No-new-privileges: The `no-new-privileges` security option prevents privilege escalation.

9.2 VM-Level Isolation (Kata Containers)

On Kubernetes, the AGF pod is scheduled with `runtimeClassName: kata-qemu`, which runs each pod inside a dedicated QEMU micro-VM with its own Linux kernel. This provides hardware-virtualization-enforced isolation, mitigating container-escape vulnerabilities that affect shared-kernel container runtimes [17].

9.3 Network Isolation

A Kubernetes NetworkPolicy enforces zero egress: the evaluation pod cannot initiate any outbound network connections. Inbound traffic is restricted to specified namespaces.

This prevents data exfiltration from the evaluation environment.

9.4 Trust Boundary Analysis

The isolation model provides defense-in-depth against workload compromise and data exfiltration. It does not provide:

- Confidential computing guarantees. Without AMD SEV-SNP, Intel TDX, or equivalent hardware, the hypervisor host and cluster administrator can inspect the pod's memory. Kata Containers provide isolation, not confidentiality.
- Remote attestation. The current system includes a TEE attestation stub that logs the isolation mode but does not produce a hardware-rooted attestation. A genuine remote-attestation flow would require TEE hardware and an attestation service.

The threat model assumes a trusted cluster administrator and infrastructure operator. Protecting against a malicious host requires upgrading to Confidential Containers with hardware TEE support — a planned enhancement documented in the roadmap.

10. Zero-Knowledge Roadmap and Verifiable Computation

10.1 Motivation

A zero-knowledge proof of compliance evaluation would allow a verifier to confirm that a specific rule evaluation was performed correctly without re-executing it and without access to the input data. This has potential applications in scenarios where:

- Entity data is confidential and cannot be shared with the verifier.
- The verifier does not have access to the evaluation environment.
- Regulatory evidence must be independently verifiable without relying on trust in the evaluation infrastructure.

10.2 Prototype Results

The AGF evaluation function has been compiled to RISC-V and proven using Succinct Labs' SP1 zkVM (v6.0.2). A conformance test suite of 19 test cases, covering all condition types and edge cases, was proven on the zkVM with the following results:

Metric	Value	Context
Execution (host)	2.77 ms (19 cases)	Direct evaluation without proving
Proving (CPU)	267.7 s (19 cases)	SP1 CPU prover, single core
Proving (GPU, estimated)	~15 s	Based on SP1 GPU acceleration benchmarks
Verification	200–300 ms	Verification of a STARK proof

These results demonstrate feasibility: the evaluation logic can be proven in a ZK setting. They do not demonstrate production readiness: proving latency of 15–270 seconds is orders of magnitude slower than direct evaluation, and proving costs are non-trivial (GPU compute time).

10.3 Current Status and Limitations

- Demonstrated, not default. ZK proving is not used in the default real-time AGF evaluation path. All routine evaluations use direct execution with Ed25519 signing and hash-chained audit entries.
 - Proving cost. At current SP1 pricing, proving 26 rules would cost significantly more than direct evaluation. Cost-effective proving at scale likely requires GPU proving clusters and further algorithmic optimization.
 - Verification does not validate data. A ZK proof confirms that the evaluation function was executed correctly on some inputs. It does not confirm that those inputs were truthful or complete.
-

11. Regulatory Mapping and Legal-Operational Fit

This section identifies regulatory provisions to which AGF's capabilities may be relevant. These are engineering assessments of alignment, not legal conclusions. Whether AGF's outputs satisfy specific regulatory requirements is a determination that must be made by qualified legal counsel and, ultimately, by supervisory authorities.

11.1 FCA Record-Keeping (SYSC 9)

FCA SYSC 9 requires firms to maintain "orderly records of [their] business and internal organisation" sufficient to enable the FCA to carry out its supervisory duties [27]. The FCA's regulatory framework is technology-neutral: it does not prohibit digital records or require specific technology implementations [28]. The FCA expects "robust security features" for digital interactions, including "encryption, multi-factor authentication, and tamper-evident audit trails" [29].

AGF's hash-chained, Ed25519-signed audit log is consistent with these technology-neutral requirements. The tamper-evident property of the hash chain and the verifiability of the digital signature are relevant capabilities. However, the admissibility of specific cryptographic formats (Blake3 hashes, Ed25519 signatures) as audit evidence under SYSC 9 has not been tested or endorsed by the FCA to our knowledge. Engagement with the FCA Innovation Hub or a formal supervisory inquiry would be appropriate before relying on such artifacts for regulatory reporting.

11.2 AML and Sanctions (MLR 2017, SAML 2018)

The Money Laundering Regulations 2017 (MLR 2017) require customer due diligence measures including identity verification, beneficial-ownership identification, and ongoing monitoring [30]. SAML 2018 provides the framework for UK financial sanctions [31]. AGF's KYC and sanctions rule files implement threshold-based checks derived from these regulations. The system can automate mechanical portions of screening (e.g., name-hash comparison against sanctions lists, jurisdictional checks) but cannot replace the judgment-dependent aspects of customer due diligence.

11.3 Capital Requirements (CRR/CRR2)

The Capital Requirements Regulation [32] establishes quantitative thresholds (e.g., 8% total capital ratio under Article 92(1)(c), 3% leverage ratio under Article 92(1)(d)). These are well-suited to ARSL formalization because they are expressed as numerical thresholds

against defined metrics. AGF can evaluate whether reported capital ratios satisfy these thresholds but does not validate the accuracy of the underlying capital calculations.

11.4 GDPR (2016/679)

GDPR provisions relating to lawful basis (Article 6), special categories (Article 9), right to erasure (Article 17), and retention (Article 5(1)(e)) [33] can be partially formalized as boolean and threshold checks (e.g., consent obtained, erasure request status, days since data collection). AGF’s GDPR vertical implements five such rules. However, GDPR compliance involves substantial qualitative elements (e.g., “legitimate interest” balancing tests, adequacy of privacy notices) that cannot be formalized as threshold comparisons.

11.5 EU AI Act (2024/1689)

The EU AI Act prohibits certain AI practices (Article 5) and imposes human-oversight requirements on high-risk AI systems (Article 14) [34]. AGF includes a rule checking whether an AI system classification falls within prohibited categories. Regarding Article 14, AGF’s deterministic evaluation model supports the interpretability dimension of human oversight — rules are transparent, version-controlled, and produce explainable per-rule results. However, determinism alone does not satisfy Article 14, which requires provision for human intervention, override capability, and awareness of automation bias [35]. An AGF deployment would need to be integrated within a broader governance framework that provides these oversight mechanisms.

11.6 MiCA (2023/1114)

The Markets in Crypto-Assets Regulation [36] establishes capital and governance requirements for crypto-asset service providers (CASPs). The quantitative prudential requirements in MiCA Title IV are analogous to CRR-style thresholds and are amenable to ARSL formalization. AGF does not currently implement MiCA-specific rules, but the architecture supports extension to this jurisdiction.

12. Benchmarking and Performance Interpretation

12.1 Reported Figures

The following measurements were obtained on the AGF prototype. They are internal measurements on a single hardware configuration and should not be extrapolated to general production performance.

Metric	Value	Conditions
26-rule multi-vertical evaluation (evaluate only)	< 0.01 ms	Pure function execution, M-series Apple Silicon
Full pipeline (parse + compile + evaluate + sign + audit)	2.77 ms	Including ARSL parsing, Blake3 hashing, Ed25519 signing
Server startup to first request	< 100 ms	Release build, no I/O-bound initialization

12.2 Interpretation Caveats

- Rule complexity. The current ARSL condition types are comparatively simple (threshold comparisons, set membership). Rules involving complex cross-field calculations, historical lookups, or large blocked-values lists would increase evaluation time.
- Scale. Performance has been measured with 26 rules. Behavior at 10,000+ rules per evaluation, or under concurrent request load, has not been benchmarked.
- Data volume. Entity data is currently passed as a flat `HashMap<String, u64>`. Large or nested data structures would require architectural changes.
- Production environment. Measurements were taken outside the Kata VM. Virtualization overhead (typically 5–15% for Kata Containers [37]) has not been factored in.
- Comparison methodology. The “2–6 weeks” estimate for manual compliance review reflects industry practice for complex assessments (e.g., onboarding due diligence). Simple checks within those assessments may already be automated in some institutions. A like-for-like comparison would require benchmarking against specific incumbent processes.

12.3 Suggested Benchmark Methodology

For future external benchmarking, we recommend:

1. Defining a standard benchmark suite of rule sets at varying complexity levels (10, 100, 1,000, 10,000 rules).
2. Measuring under controlled concurrent load (1, 10, 100 requests/second).
3. Including Kata VM overhead in measurements.
4. Separating parse/compile latency from evaluation latency.
5. Reporting P50, P95, and P99 latencies, not only means.

13. Comparison with Existing Approaches

Capability	Manual Review	GRC Platforms	Policy-as-Code (OPA)	AGF
Evaluation reproducibility	Low — depends on analyst	Low — depends on workflow	High — deterministic	High — deterministic
Evaluation speed	Days-weeks	Hours-days (workflow)	Milliseconds	Milliseconds
Rule formalization	Not applicable	Informal	Rego/Sentinel policies	ARSL (TOML-based); OPA-class paths optional at compile boundary
Audit trail integrity	Trust-based (logs, PDFs)	Database-backed	Application-logged	Blake3 hash chain + Ed25519
Third-party verifiability	Not available	Not available	Not standard	Available (agf-verify CLI)

Capability	Manual Review	GRC Platforms	Policy-as-Code (OPA)	AGF
ZK proof path	Not applicable	Not applicable	Not standard	Demonstrated prototype only (SP1 zkVM); not default real-time path
Trust/risk scores vs formal rules	Implicit judgment	Workflow/risk apps	Typically policy-only	Scores orchestrate in control plane; kernel decides via rules
Input data validation	Analyst judgment	Process-dependent	Out of scope	Out of scope
Regulatory endorsement	Established practice	Established practice	Not yet	Not yet

This comparison is necessarily simplified. In practice, incumbent systems have extensive integrations, established regulatory acceptance, and operational maturity that a prototype system lacks. AGF's advantages are primarily in evaluation verifiability and reproducibility — properties that are novel in the compliance context but do not substitute for the organizational, procedural, and judgment capabilities of established compliance operations.

14. Limitations, Assumptions, and Open Questions

14.1 Data Integrity

AGF evaluates data as provided. If input data is incorrect, incomplete, fabricated, or stale, the evaluation result will be correspondingly unreliable, regardless of the cryptographic integrity of the audit trail. A cryptographically signed incorrect result is still incorrect. Upstream data-quality controls, source-of-truth validation, and data-lineage tracking are necessary complements that AGF does not provide.

14.2 Rule Formalization Risk

The translation from natural-language regulation to ARSL rules is an interpretive act performed by engineers and subject-matter experts. This translation may introduce errors, omissions, or oversimplifications. Different firms or jurisdictions may interpret the same regulation differently. Regulatory text may contain ambiguities, exceptions, or judgment-dependent qualifications that cannot be captured by the current ARSL condition types. Legal review of rule definitions and formal change-control processes are essential.

14.3 Jurisdictional Interpretation

The prototype rules reference UK (FCA, HMT), EU (ECB, ESMA, ICO), and US (OFAC) regulations. Regulatory requirements are not static: thresholds change, new rules are introduced, and supervisory expectations evolve through guidance and enforcement actions.

A production system requires continuous monitoring of regulatory updates and timely revision of ARSL rule files — a significant operational obligation.

14.4 Key Management

The security of the Ed25519 signing model depends on the confidentiality and integrity of the private key. The prototype loads the key from an environment variable, which is provisioned as a Kubernetes Secret. This approach is acceptable for development but has known limitations:

- Kubernetes Secrets are base64-encoded, not encrypted at rest by default (etcd encryption must be configured separately).
- There is no key-rotation mechanism: rotating the key requires manual reprovisioning.
- There is no revocation protocol: if the key is compromised, previously signed results cannot be distinguished from fraudulently signed ones without additional context.

A production deployment should use a hardware security module (HSM) or cloud KMS for key storage, implement automated key rotation, and publish key-validity periods alongside signatures.

14.5 TEE and Attestation Limitations

The current system uses Kata Containers for VM-level isolation but does not include hardware-based attestation. The TEE attestation report in the current implementation is a stub — a software-generated structure indicating the runtime class, not a hardware-rooted measurement. Without AMD SEV-SNP, Intel TDX, or equivalent technology, the system does not provide guarantees against a malicious host operator or compromised hypervisor. The roadmap includes upgrading to Confidential Containers with hardware attestation when compatible hardware is available in the deployment environment.

14.6 Privacy and Metadata Leakage

The signed evaluation result includes the decision (PASS/BLOCK), rule pass/fail counts, entity ID, and timing information. While entity data fields are not directly included in the signed artifact, the combination of entity ID, decision outcome, per-vertical decision, and timestamp may constitute information that raises privacy concerns. The hash-based field encoding used internally (e.g., country hashes, name hashes) provides obfuscation but not formal privacy guarantees. A rigorous privacy analysis — potentially leveraging differential privacy or the ZK proof path to reduce artifact metadata — would be needed for deployments handling sensitive personal data.

14.7 Benchmark Realism

As noted in Section 12, the reported performance figures reflect a prototype implementation with 26 simple rules. Whether these figures scale to production workloads with thousands of rules, complex conditions, and high concurrency is unknown. The reported figures should be treated as demonstration metrics, not production SLA commitments.

14.8 Regulatory Acceptance

No regulatory authority has, to our knowledge, endorsed or evaluated AGF or any comparable cryptographic compliance engine. The FCA Innovation Hub and equivalent sandbox

programs in other jurisdictions provide pathways for exploratory engagement. However, the adoption of cryptographic audit artifacts as a substitute for or supplement to traditional compliance records will require regulatory dialogue, legal analysis, and potentially supervisory guidance or policy change.

14.9 Unified product scope and control-plane maturity

This document describes a unified architecture concept: a governance control plane paired with the enforcement kernel described in the body of the paper. Not every control-plane capability (broad multi-framework SDK coverage, production-grade DID infrastructure, turnkey HSM/KMS integrations, full HITL product workflows) is implied to be complete in every prototype deployment. Readers should treat the kernel and cryptographic claims as the primary technical subject matter; operator UX and integration breadth may trail the kernel in maturity.

15. Future Work

1. Optional ZK assurance (off hot path). Continue SP1 and related zkVM research for batch or high-assurance scenarios where multi-second to minute-scale proving latency is acceptable — explicitly not as a replacement for the default real-time evaluation and Ed25519-signed audit path used for agent action gating.
 2. Hardware attestation. Upgrade to Confidential Containers with AMD SEV-SNP or Intel TDX for hardware-rooted attestation.
 3. Key management. Integrate with an HSM or cloud KMS for key storage and automated rotation. Implement key-validity period metadata in signatures.
 4. Extended rule semantics. Add support for cross-field calculations, temporal conditions (e.g., “within the last 30 days”), and hierarchical entity structures.
 5. Machine-readable regulation integration. Explore integration with FCA Digital Regulatory Reporting or other MRR initiatives to reduce formalization risk.
 6. Multi-jurisdictional rule reconciliation. Develop tooling for identifying overlapping or conflicting rules across UK, EU, and US jurisdictions.
 7. Formal verification of ARSL semantics. Apply formal methods to verify that the ARSL compiler and evaluation function correctly implement the intended rule semantics.
 8. External benchmarking. Conduct benchmarks under the methodology described in Section 12.3 and publish results with reproducible configurations.
-

16. Conclusion

AGF demonstrates that a significant class of compliance evaluations can be performed deterministically, signed cryptographically, and recorded in a tamper-evident audit log. The system provides a reproducible, verifiable record of compliance evaluation that is independent of trust in any individual reviewer or system administrator — an improvement over the status quo of trust-based compliance documentation.

In a full product, that kernel is complemented by a governance control plane (policy lifecycle, identities, trust signals, HITL, reporting, integrations). The value proposition is formal enforcement plus operator-ready governance, with scores and workflows subordinate to rule-based outcomes.

However, the system operates within defined boundaries. It does not validate input data, does not replace legal interpretation of regulatory text, and does not itself constitute legal compliance. The cryptographic audit trail provides integrity guarantees over the evaluation process, not over the truth of the inputs or the correctness of the rule formalization. These limitations are inherent to any computational compliance system and must be addressed through complementary governance, data-quality, and legal-review processes.

The zero-knowledge proof path offers a compelling optional capability — proving correct evaluation without revealing inputs to a verifier — but remains a research and batch-oriented objective, not the default real-time production path. Similarly, hardware-based confidential computing and remote attestation are planned enhancements that depend on infrastructure available in the deployment environment.

We believe the approach merits further investigation and regulatory engagement, and we present this work as a contribution to the broader discussion of how cryptographic systems can improve the reliability, verifiability, and efficiency of regulatory compliance processes.

References

- [1] LexisNexis Risk Solutions. “True Cost of Financial Crime Compliance Study — Global Report.” 2024. Available: <https://risk.lexisnexis.com/insights-resources/research/true-cost-of-financial-crime-compliance-study-global-report>
- [2] Sayari, Inc. “Rising Compliance Costs and Bank IT Budget Allocation 2016–2023.” Analysis based on BPI survey data, 2024.
- [3] Bank Policy Institute (BPI). “Compliance Cost Survey: Employee Hours Dedicated to Financial Regulation.” 2024.
- [4] CUBE (formerly Thomson Reuters Regulatory Intelligence). “Cost of Compliance Report 2025.” 15th edition. Survey of 2,000+ senior compliance and risk officers.
- [5] Flagright. “Understanding False Positives in Transaction Monitoring.” Industry analysis. Available: <https://flagright.com>
- [6] Columbia University School of International and Public Affairs. “AML Transaction Monitoring False Positive Rates.” Research report, cited in multiple industry analyses.
- [7] S. C. Myers et al. “Alert Fatigue and False Positives in Financial Crime Compliance.” Multiple industry reports, 2023–2024.
- [8] LexisNexis Risk Solutions. “Sanctions False Positive Alert Fatigue.” True Cost study supplement, 2024.
- [9] Open Policy Agent (OPA). “Policy as Code.” <https://www.openpolicyagent.org>. Cloud Native Computing Foundation project.
- [10] D. Arner, J. Barberis, R. Buckley. “FinTech, RegTech, and the Reconceptualization of Financial Regulation.” *Northwestern Journal of International Law & Business*, 37(3), 2017.
- [11] Be Informed. “Machine-Readable Regulation: Structuring Regulatory Domains for Predictability and Scalability.” Industry whitepaper.
- [12] Financial Conduct Authority. “Digital Regulatory Reporting.” TechSprint and pilot

programme, 2017–present. Available: <https://fca.org.uk/innovation/regtech/digital-regulatory-reporting>

[13] S. Roy. “Regulators Should Treat Machines as a Primary Audience for Regulatory Text.” Academic working paper on machine-readable regulation.

[14] B. Laurie, A. Langley, E. Kasper. “Certificate Transparency.” RFC 6962 (Experimental), IETF, June 2013.

[15] Google. “Trillian: A General Transparency Merkle Tree.” Open-source project. <https://github.com/google/trillian>

[16] Confidential Computing Consortium. “Confidential Computing: Hardware-Based Trusted Execution for Applications and Data.” Technical overview, Linux Foundation.

[17] Kata Containers. “Kata Containers: The Speed of Containers with the Security of VMs.” OpenInfra Foundation project. <https://katacontainers.io>

[18] Succinct Labs. “SP1: A Performance-Optimized zkVM.” <https://docs.succinct.xyz/sp1>

[19] RISC Zero. “RISC Zero zkVM.” <https://risczero.com>

[20] a16z crypto. “Jolt: SNARKs for Virtual Machines via Lookups.” Conference paper and implementation.

[21] Succinct Labs. “SP1 v1.1.1: Production-Ready Release.” Blog post, August 2024.

[22] Succinct Labs. “SP1 Hypercube: Real-Time Proving for Ethereum Blocks.” Announcement, May 2025.

[23] S. Josefsson, I. Liusvaara. “Edwards-Curve Digital Signature Algorithm (EdDSA).” RFC 8032, Internet Research Task Force, January 2017.

[24] J. O’Connor, J.-P. Aumasson, S. Neves, Z. Wilcox-O’Hearn. “BLAKE3: One Function, Fast Everywhere.” Specification and reference implementation, 2020. <https://github.com/BLAKE3-team/BLAKE3>

[25] J.-P. Aumasson. “The BLAKE3 Hashing Framework.” Internet-Draft draft-aumasson-blake3-00. IETF, expired.

[26] National Institute of Standards and Technology (NIST). “Digital Signature Standard (DSS).” FIPS PUB 186-5, anticipated to include Ed25519.

[27] Financial Conduct Authority. “SYSC 9: Record Keeping.” FCA Handbook. <https://www.handbook.fca>

[28] Ratifio. “FCA Technology-Neutral Framework for Digital Records and Electronic Signatures.” Industry analysis, 2024.

[29] eSignGlobal. “FCA Expectations for Digital Interaction Security Features.” Regulatory compliance guide, 2024.

[30] UK Government. “Money Laundering, Terrorist Financing and Transfer of Funds (Information on the Payer) Regulations 2017.” S.I. 2017/692.

[31] UK Government. “Sanctions and Anti-Money Laundering Act 2018.” c. 13. <https://www.legislation.gov.uk/ukpga/2018/13/contents>

[32] European Parliament and Council. “Regulation (EU) No 575/2013 on Prudential Requirements for Credit Institutions (CRR).”

[33] European Parliament and Council. “Regulation (EU) 2016/679 on the Protection of Natural Persons (GDPR).”

[34] European Parliament and Council. "Regulation (EU) 2024/1689 Laying Down Harmonised Rules on Artificial Intelligence (EU AI Act)."

[35] artificialintelligenceact.eu. "Article 14: Human Oversight." Annotated reference and discussion.

[36] European Parliament and Council. "Regulation (EU) 2023/1114 on Markets in Crypto-Assets (MiCA)."

[37] Kata Containers. "Performance Overview and Virtualization Overhead." Project documentation and community benchmarks.

Appendix A: Claims Intentionally Softened or Removed

#	Original Claim	Action	Rationale
1	"\$270B annually"	Revised to \$206B	Original figure not traceable to any published source
2	"80% of compliance checks are manual"	Softened to "significant majority"	No authoritative primary source for the specific percentage
3	"False positive rates exceed 95%"	Revised to "90–95% range"	Industry sources report a range, not a firm floor
4	"Hash chain + signatures = mathematically impossible to tamper"	Revised to "computationally infeasible under standard assumptions"	Absolute impossibility is a stronger claim than warranted
5	"Deterministic evaluation satisfies Article 14 human oversight"	Revised to "supports the interpretability dimension"	Article 14 requires intervention, override, and bias awareness capabilities beyond determinism
6	"Exceeds evidentiary requirements of FCA SYSC 9"	Revised to "consistent with technology-neutral requirements"	"Exceeds" is a legal conclusion that requires supervisory determination
7	"< £0.001 cost per evaluation"	Revised to "marginal compute cost" with caveats	Ignores infrastructure, operational, and total-cost-of-ownership considerations

#	Original Claim	Action	Rationale
8	"Any third party can verify without underlying data"	Qualified to specify what is and is not verifiable	Third-party verification confirms signature integrity, not data truthfulness
9	"Kata Containers = hardware-grade isolation"	Revised to distinguish VM isolation from confidential computing	Kata provides isolation but not confidentiality without TEE hardware
10	"SP1 ZK proofs" presented alongside production features	Separated into "demonstrated" section with explicit non-production caveat	Conflating demonstrated capability with deployed feature is misleading

Appendix B: Sample ARSL Rule

rules/fca/consumer_duty.arsl.toml – Rule 1 of 10

```
[[rule]]
id = "FCA-CD-001"
name = "Capital Adequacy Ratio"
description = "Total capital must be at least 8% of risk-weighted assets"
category = "capital"
severity = "critical"
entity_type = "uk_bank"

[rule.source]
regulation = "CRR"
article = "Article 92(1)(c)"
text = "An institution shall at all times satisfy a total capital ratio of 8%"

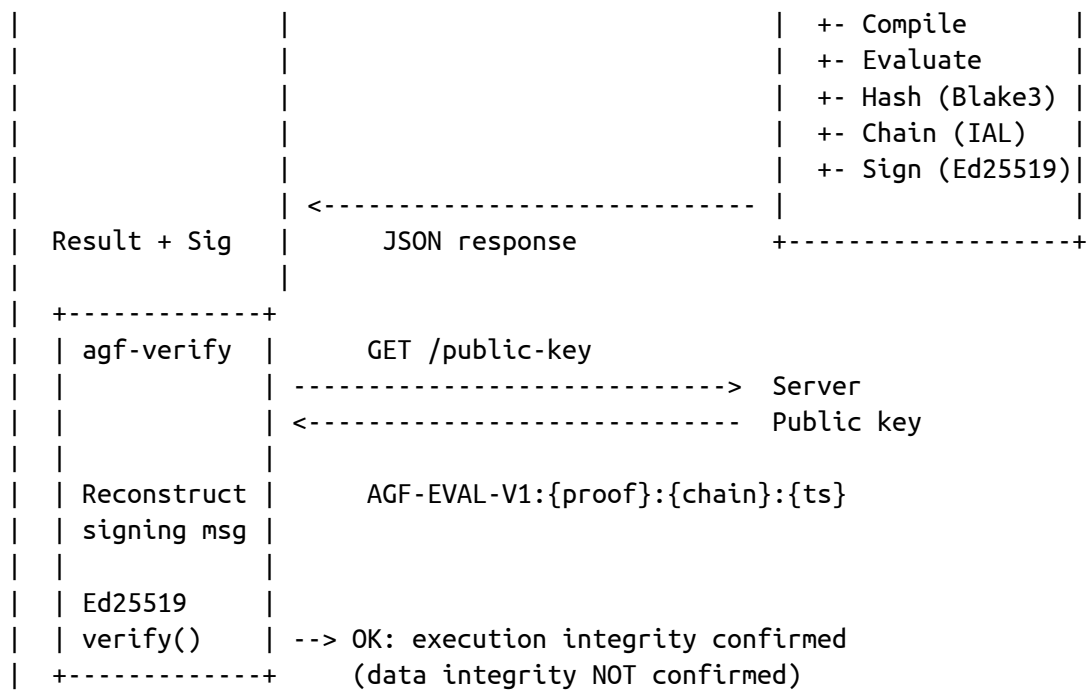
[rule.condition]
type = "minimum"
field = "capital_ratio"
threshold = 800      # 8.00% expressed as basis points
unit = "bps"

[rule.enforcement]
on_pass = "allow"
on_fail = "block"
```

Appendix C: Verification Flow

ASCII diagram (PDF-friendly monospace):

```
+-----+          POST /evaluate-entity          +-----+
| Client / Demo | -----> | AGF Server          |
|               |          | +- Parse ARSL      |
```

Appendix D: Glossary

Term	Definition
ARSL	AGF Rule Specification Language — TOML-based DSL for defining compliance rules
IAL	Immutable Audit Log — Blake3 hash-chained append-only audit trail
ComplianceBatch	Typed intermediate representation of compiled rules and evaluation inputs
Control plane	Governance layer for configuration, identities, trust signals, HITL, reporting, and integrations — does not execute isolated kernel evaluation
Enforcement kernel	The isolated subsystem that compiles and evaluates rules and produces signed IAL entries
Decentralized Identifier (DID)	Standard-style identifier for attributing agent or service actions in audit and control-plane systems
Human-in-the-loop (HITL)	Governance pattern where some outcomes require explicit human approval after policy evaluation
Formalization risk	Risk that the translation from regulatory text to executable rules introduces errors or omissions
Tamper-evident	Property ensuring that modification of recorded data is detectable
TEE	Trusted Execution Environment — hardware-enforced isolated execution

Term	Definition
zkVM	Zero-knowledge Virtual Machine — system for proving correct program execution
Basis points (bps)	Unit of measure equal to 0.01 percentage points

This document is provided for informational purposes. It does not constitute legal advice. Organizations should seek qualified legal counsel before relying on any technical system for regulatory compliance. NeuroCluster makes no representation that use of AGF will result in compliance with any specific law or regulation.